نقشه عملیاتی فاز ۳ RAG_finance

Multi-user Chat و Deployment، Website Launch، Database

Repository	Shahbazi-Amir/RAG_finance
Branch مبنا	rag-phase2
Commit ممیزی	96c0f0c7d09f4bff107ed71664a0c57ed09f3214
تاریخ نسخه	۲۱ اوت ۲۰۲۶
دامنه	لانچ سایت چندکاربره؛ خارج از مربی شخصی کامل

۱. شرط ورود

فاز ۳ شروع نمی‌شود مگر اینکه فاز ۲ این موارد را تحویل دهد:

- RAG API contract و خروجی ساخت‌یافته Answer/Claims/Citations.
- Dataset، Index، Model، Prompt، Policy و Eval release IDs.
- health/readiness contract و Known limitations.
- Golden regression baseline.
- Citation links قابل بازشدن برای سه منبع.

۲. معماری مرجع

—├ Browser / PWA ↓ Reverse Proxy + TLS ↓ Next.js Web → FastAPI Application ├── PostgreSQL
Redis ├── RAG Core → Qdrant ├── LLM Gateway └── Object Storage

پیشنهاد فعلی بر اساس فایل تصمیم‌سازی: Modular Monolith. Microservice و Kubernetes تا زمانی که بار واقعی ضرورت آن را ثابت نکرده، اضافه نشوند.

تصمیم‌های نیازمند تثبیت پیش از اجرا:

- سرور و محل میزبانی.
- مدل API یا Self-host و محدودیت انتقال داده.
- روش ورود.
- DAU، پیام روزانه، همزمانی و بودجه AI.
- Retention و حذف داده.

در صورت نبود این تصمیم‌ها، مقدار قطعی زیرساخت و هزینه را نمی‌توان تعیین کرد.

۳. بسته P3-01 - Product و Architecture Contract

کارها

- تعریف User journey ثبت‌نام تا چت و مشاهده Source.
- تعریف نقش‌ها: user، support و admin محدود.
- API versioning، error model و idempotency policy.
- Threat model و data classification.
- ADR برای modular monolith، hosting، auth، queues و LLM gateway.

خروجی

- docs/architecture/phase3.md
- docs/api/openapi.yaml
- docs/security/threat_model.md
- /docs/adr

Gate

API، مدل اعتماد، مرز داده شخصی و مسئول هر سرویس تصویب شده باشد.

۴. بسته P3-02 - مدل داده PostgreSQL

موجودیت‌های فعال

- users، identities، sessions و consents.
- conversations، messages و citations.
- model_runs، retrieval_runs و feedback.
- security_events، audit_events و deletion_requests.

موجودیت‌های رزروشده برای فاز ۴

- financial_profiles و financial_snapshots.
- goals، scores، assessments و action_plans.
- risk_flags و human_referrals.

قواعد

- همه داده‌های کاربر user_id یا tenant_id داشته باشند.
- Migrationها نسخه‌دار و rollback plan داشته باشند.
- PII از log و model payload تا حد ممکن حذف شود.
- uniqueness، Foreign key و retention job تست شود.

Gate

Migration از DB خالی موفق و تست cross-user access برای تمام جداول حساس پاس شود.

۵. بسته P3-03 - Auth، Consent و Isolation

کارها

- ثبت‌نام، ورود، session rotation، logout و password reset.
- password hashing استاندارد، cookie امن و CSRF/CORS policy.
- consent version، تاریخ پذیرش و امکان پس‌گرفتن.
- Row-Level Security و FORCE RLS در جداول کاربر.
- تست‌های منفی افقی و عمودی دسترسی.
- rate limit برای login، chat و feedback.

PostgreSQL امکان اعمال Policy در سطح سطر را فراهم می‌کند؛ نبود Policy پس از فعال‌سازی RLS حالت default-deny ایجاد می‌کند، اما owner و نقش‌های BYPASSRLS باید در طراحی و تست کنترل شوند. مرجع: https://www.postgresql.org/docs/current/ddl-rowsecurity.html

Gate

هیچ User A نتواند با API، شناسه یا Query تغییریافته، داده User B را بخواند یا تغییر دهد.

۶. بسته P3-04 - Application API و RAG Orchestration

Endpointهای حداقلی

- auth و session.
- create/list conversation.
- send message و stream answer.
- get answer details/citations.
- submit feedback.
- export/delete account data.
- health، readiness و version.

ثبت هر پاسخ

- original/processed query.
- dataset/index/retrieval/reranker/model/prompt/policy versions.
- retrieved و selected chunk IDs.
- answer claims/citations.
- latency، tokens، cost estimate و status.

قواعد

- timeout، retry و circuit breaker برای providerها.
- request_id و trace_id سراسری.
- پاسخ Cache فقط با Version-compatible key.
- هیچ fallback نباید silently پاسخ بدون Citation بسازد.

Gate

قرارداد فاز ۲ بدون از دست رفتن abstention، Citation یا version metadata در API ارائه شود.

۷. بسته P3-05 - Web/PWA و تجربه چت

صفحات پایه

- landing و توضیح مرز محصول.
- signup/login/consent.
- conversation history، chat و source drawer.
- account/privacy/export/delete.
- feedback و report answer.

رفتار چت

- Streaming پاسخ و وضعیت retrieving/generating.
- Citation کنار Claim و صفحه جزئیات منبع.
- پیام واضح برای ambiguity، no-answer و safety refusal.

- نمایش اینکه پاسخ آموزشی است و چه منبعی استفاده شده.
- دسترس‌پذیری، RTL، موبایل و خطاهای بازیابی.

Gate

مسیر اصلی روی موبایل و دسکتاپ، با network failure و refresh، بدون از دست رفتن یا اختلاط مکالمه کار کند.

۸. بسته P3-06 - زیرساخت و Deployment

اجزا

- Docker images نسخه‌دار برای Web، API و Worker.
- PostgreSQL، Qdrant، Redis و Object Storage مدیریت‌شده یا self-host بر اساس تصمیم.
- domain، TLS، Reverse proxy و secure headers.
- environment separation برای local/staging/production.
- secrets management و rotation.
- migrations و seedهای کنترل‌شده.

Release

- CI: lint، unit، integration، security و build.
- CD با smoke test، migration gate، approval و rollback.
- Infrastructure/Deployment runbook.
- Release manifest شامل app و RAG artifact versions.

Gate

Staging و Production از روی دستور مستند ساخته شوند و rollback یک Release آزمایشی اجرا شود.

۹. بسته P3-07 - Backup، Restore و Data Lifecycle

- backup رمزگذاری‌شده PostgreSQL و Qdrant snapshot.
- retention و lifecycle برای object/log.
- restore drill و گزارش RPO/RTO واقعی.
- export و deletion workflow.
- tombstone/audit برای حذف و عدم بازگشت ناخواسته از backup.

Gate

Restore روی محیط جدا انجام و consistency مکالمه، Citation و Release IDs بررسی شود.

۱۰. بسته P3-08 - Observability و عملیات

Metrics

- request rate، error rate و latency p50/p95.
- retrieval/generation latency و provider errors.
- token/cost per successful answer.
- citation/no-answer/policy outcomes.
- cache hit و queue depth.

- DB/Qdrant health و saturation.

عملیات

- structured logs بدون PII.
- traces بین Web/API/RAG/LLM.
- alerts، on-call contacts و incident runbook.
- admin operational view حداقلی؛ پنل گسترده در فاز ۴.

Gate

یک failure تزریقی قابل تشخیص، alert و ریشه‌یابی باشد و log آن داده حساس نداشته باشد.

۱۱. بسته P3-09 - Security و GenAI Hardening

- prompt injection tests برای Query و Retrieved content.
- output validation و safe rendering.
- access control روی Sourceهای غیرعمومی.
- dependency/container scanning و SBOM.
- secret scanning، audit log و admin access review.
- abuse، rate/cost limit و denial-of-wallet controls.
- test برای sensitive information disclosure.

OWASP در نسخه جاری GenAI، Prompt Injection، افشای اطلاعات حساس، handling ناامن خروجی و agency بیش از حد را از ریسک‌های اصلی می‌داند. مرجع: https://owasp.org/www-project-top-10-for-large-language-model-applications/

Gate

هیچ finding بحرانی باز در تست امنیت، cross-user و LLM red-team وجود نداشته باشد.

۱۲. بسته P3-10 - Performance و Capacity

سناریوهای تست

- chat cached و uncached.
- پاسخ کوتاه/بلند و چند Citation.
- provider کند یا unavailable.
- sustained load، spike و concurrent conversations.
- DB و Qdrant degradation.

Targetهای اولیه غیرقراردادی

- Availability پایلوت: 99.5٪.
- p95 مسیر غیر AI: کمتر از 500ms.
- p95 پاسخ AI: ترجیحاً کمتر از 15s، وابسته به مدل.
- concurrent limit، error budget و daily cost cap پس از Load test فریز شوند.

Gate

Capacity report بر مبنای بار واقعی و Cost model وجود داشته باشد؛ عدد ۱۵۰۰ تا ۲۰۰۰ کاربر ثبت‌شده به‌تنهایی sizing محسوب نشود.

۱۳. بسته P3-11 - Beta و Launch

مراحل

1. Internal alpha با حساب‌های تست.
2. Closed beta با گروه محدود.
3. رفع P0/P1 و کنترل هزینه/کیفیت.
4. Production launch محدود.
5. افزایش تدریجی ظرفیت با feature flags.

Launch checklist

- Domain/TLS و privacy/terms links.
- backup/restore و rollback تست‌شده.
- monitoring/alerts فعال.
- support و incident ownership مشخص.
- RAG regression و security gate پاس.
- data deletion/export آماده.
- analytics حداقلی و consent-aware.

Gate

کاربر واقعی بتواند به‌صورت پایدار ثبت‌نام و چت کند؛ Citation و تاریخچه درست باشد و rollback آماده باشد.

۱۴. تست‌های اجباری

- Unit و contract tests.
- API integration و DB migration.
- RLS/cross-user negative tests.
- End-to-end browser flow.
- RAG regression و citation links.
- load، soak و provider failure.
- backup/restore.
- OWASP web/API و GenAI tests.
- accessibility و RTL.

۱۵. ساختار پیشنهادی

/apps/ web/ api/ packages/ rag_client/ contracts/ observability/ infra/ docker/ environments /migrations/ tests/ unit/ integration/ e2e/ security/ load/ docs/ architecture/ api/ security/ operations /adr/

۱۶. شواهد دانش فنی فاز ۳

- معماری tenancy و RLS با تست‌های منفی.
- RAG version trace از UI تا Dataset.
- LLM gateway و provider benchmark.
- threat model و GenAI security report.
- load/cost/capacity report.
- backup/restore و incident drill.
- release manifest، CI/CD و rollback evidence.
- failure analysis و ADRهای انتخاب معماری.

۱۷. Gate نهایی و تحویل به فاز ۴

- Web/PWA و API Production فعال.
- کاربران، consent، مکالمه و citation در PostgreSQL.
- backup، security، isolation و observability اثبات‌شده.
- RAG artifact versions در هر پاسخ ثبت‌شده.
- event schema برای learning، assessment و action آماده.
- extension points برای Assessment، Rules و Admin تصویب‌شده.

۱۸. خارج از فاز ۳

- آزمون و سطح‌بندی کامل.
- پروفایل مالی و محاسبات شخصی.
- برنامه اقدام و Check-in.
- پنل حرفه‌ای مدیریت محتوا/کاربر/آزمون.
- توصیه سرمایه‌گذاری و خریدوفروش.
- اپ Native، پرداخت و اتصال بانکی.

فاز ۳ یک «دموی روی سرور» نیست؛ محصول چت مستند چندکاربره و قابل عملیات است. اما هنوز مربی کامل سواد مالی نیست.